

JOHN THE RIPPER THE BASICS

[Kaynak](#)

İÇERİK

1. John the Ripper: Temel Kavramlar ve Hash Mekanizması
2. Sistem Kurulumu ve Gerekli Araçlar
3. Temel Hash'leri Kırma (Cracking Basic Hashes)
4. Windows Kimlik Doğrulama Hash'lerini Kırma (NTHash / NTLM)
5. Linux /etc/shadow Hash'lerini Kırma (Unshadowing İşlemi)
6. John the Ripper: Single Crack Mode
7. John the Ripper: Custom Rules (Özel Kurallar)
8. Parola Korumalı Zip Dosyalarını Kırma
9. Parola Korumalı RAR Arşivlerini Kırma
10. John the Ripper: SSH Anahtarlarını (id_rsa) Kırma

John the Ripper: Temel Kavramlar ve Hash Mekanizması

Bu notlar, parola kırma (password cracking) süreçlerinin temel taşı olan hash mantığını ve bu alandaki en güçlü araçlardan biri olan **John the Ripper**'in çalışma prensibini anlamak için oluşturulmuştur. Bir siber güvenlik uzmanı için sadece aracı çalıştırmayı bilmek yetmez; arka plandaki matematiksel imkansızlığı ve bu imkansızlığın nasıl "atlatıldığını" kavramak gerekir.

Hash (Özet) Nedir?

Hash, herhangi bir boyuttaki veriyi alıp, onu **sabit uzunlukta** başka bir forma dönüştürme işlemidir. Bu işlem sonucunda elde edilen veriye "hash değeri" veya "fingerprint" (parmak izi) denir. Hash fonksiyonlarının temel amacı, orijinal veriyi maskeleyerek ve verinin bütünlüğünü korumaktır.

Bir veriyi hashlediğimizde, kullandığımız algoritma (MD4, MD5, SHA1 veya NTLM gibi) bize her zaman aynı uzunlukta bir çıktı verir.

Örneklerle İnceleyelim:

- **"polo"** (4 karakterli bir string) verisini **MD5** algoritmasından geçirirsek:
b53759f3ce692de7aff1b5779d3964da (32 karakterlik bir hash) elde ederiz.
- **"polomints"** (9 karakterli bir string) verisini aynı **MD5** algoritmasından geçirirsek:
584b6e4f4586e136bc280f27f9c64f3b (yine 32 karakterlik bir hash) elde ederiz.

Kritik Nokta: Girdi ne kadar uzun olursa olsun, MD5 her zaman 32 karakterlik (128-bit) bir çıktı üretir. Bu durum, verinin boyutundan bağımsız olarak standart bir saklama formatı sağlar.

Hash Fonksiyonlarını "Güvenli" Kılan Nedir?

Hash fonksiyonları **tek yönlü (one-way)** fonksiyonlar olarak tasarlanmıştır. Bu, siber güvenliğin en temel kurallarından biridir: Veriden hash'e gitmek çok kolay ve hızlıdır, ancak hash'ten orijinal veriye dönmek (un-hashing) matematiksel olarak imkansıza yakındır.

Bu imkansızlık, bilgisayar bilimindeki **P vs NP** problemiyle doğrudan ilişkilidir:

- **P (Polynomial Time - Polinom Zaman):** Çözümü makul bir sürede bulunabilen problemlerdir. Örneğin, bir listeyi alfabetik sıraya dizmek. Liste uzasa da gereken süre tahmin edilebilir ve kontrol edilebilir bir oranda artar. Hash oluşturma algoritması bir **P** problemidir; bilgisayar bunu saniyeler içinde yapar.
- **NP (Non-deterministic Polynomial Time):** Bir çözümün doğru olup olmadığını kontrol etmenin çok hızlı olduğu, ancak o çözümü ilk başta bulmanın çok zor (veya imkansız) olduğu problemlerdir.

Bir hash değerini "tersine çevirmek" bir **NP** problemidir. Standart bir bilgisayarın bu matematiksel labirenti çözerek orijinal şifreyi bulması binlerce yıl sürebilir. Bu yüzden hash'ler, veriyi geri döndürülemez şekilde saklamak için mükemmeldir.

John the Ripper (John) Burada Nereye Devreye Giriyor?

Eğer bir algoritma tersine çevrilemiyorsa (irreversible), biz bu şifreleri nasıl kırıyoruz? Cevap: **Tersine çevirerek değil, sürekli ileriye doğru deneyerek.**

İşte **John the Ripper (JTR)** tam olarak bu noktada devreye girer. John, karmaşık matematiksel denklemleri çözmeye çalışmaz. Bunun yerine **Dictionary Attack (Sözlük Saldırısı)** denilen yöntemi kullanır:

1. **Elimizde ne var?** Kırmak istediğimiz bir hash değeri (Örn: b537...) ve bu hash'in hangi algoritmayla (Örn: MD5) oluşturulduğu bilgisi.
2. **Sözlük Hazırlığı:** İçinde milyonlarca olası şifrenin bulunduğu bir liste (wordlist) kullanılır.
3. **Karşılaştırma Döngüsü:** John, sözlükteki her bir kelimeyi tek tek alır, MD5 algoritmasıyla hash'ler ve çıkan sonucu bizim elimizdeki hedef hash ile karşılaştırır.
4. **Eşleşme (Match):** Eğer sözlükteki "123456" kelimesinin hash'i, bizim kırmaya çalıştığımız hash ile birebir aynıysa, tebrikler! Şifreyi buldunuz.

John the Ripper, bu süreci inanılmaz derecede yüksek hızlarda yapabilen, çok sayıda hash tipini (Windows NTLM, Linux Shadow, ZIP/PDF şifreleri vb.) tanıyan bir kaba kuvvet (brute force) aracıdır.

Özet ve Hatırlatma

- **Hash:** Verinin sabit uzunluktaki dijital imzasıdır.
- **Tek Yönlülük:** Girdiden çıktıya gitmek kolay (**P**), çıktıdan girdiye gitmek imkansızdır (**NP**).
- **Kırma Mantığı:** Algoritmayı tersine çevirmek yerine, olası tüm kelimeleri hashleyip hedefle karşılaştırmak.
- **Jumbo John:** Bu oda boyunca, John the Ripper'ın çok daha fazla algoritma ve özellik içeren genişletilmiş sürümü olan **Jumbo John**'u kullanacağız.

Sistem Kurulumu ve Gerekli Araçlar

Bu bölümde, John the Ripper'ın (JTR) doğru sürümünü kurduğumuzdan emin olacağız ve parola kırma işlemlerinin "yakıtı" olan sözlükleri (wordlists) hazırlayacağız. Unutma, yanlış sürüm kullanmak **zip2john** gibi kritik yardımcı araçlardan mahrum kalmana neden olur.

1. John the Ripper Sürümleri: Core vs. Jumbo

John the Ripper'ın iki ana sürümü vardır. Aralarındaki fark, bir siber güvenlikçi için hayati önem taşır:

- **Core (Standart) Sürüm:** Temel hash kırma işlevlerini içeren resmi sürümdür. Çoğu Linux deposunda (`apt install john` gibi) bu sürüm bulunur.
- **Jumbo John:** Topluluk tarafından geliştirilen, Core sürümünün üzerine inşa edilmiş devasa bir eklenti paketidir.
 - **Neden Jumbo?** Çünkü Jumbo sürümü; Windows NTLM, PDF, ZIP, RAR gibi yüzlerce ek hash tipini destekler. Ayrıca şifreli dosyaları hash formatına çeviren **zip2john**, **rar2john**, **ssh2john** gibi yardımcı araçlar sadece bu sürümde mevcuttur.

Kurulum Kontrolü

Sisteminde hangi sürümün olduğunu anlamak için terminale şu komutu yaz:

Bash

```
john
```

Çıktı Analizi: Terminalde kullanım kılavuzu (usage guide) açılmalıdır. İlk satırda `John the Ripper 1.9.0-jumbo-1` (veya benzeri bir sürüm numarası ile birlikte **jumbo** ibaresi) görmelisin. Eğer "jumbo" yazmıyorsa, birçok gelişmiş özelliği kullanamayacaksın demektir.

- **Kali Linux / AttackBox:** Bu sistemlerde Jumbo sürümü halihazırda yüklü gelir. Ek işlem yapmana gerek yoktur.
- **Standart Linux (Ubuntu/Fedora):** Depolardaki sürüm genellikle Core sürümdür. Tüm araçlara erişmek için **kaynak koddan derleme (build from source)** yapman önerilir.
- **Windows:** Jumbo sürümünün binary (exe) dosyalarını içeren .zip arşivini indirip çıkartarak kullanabilirsin.

2. Wordlist (Kelime Listesi) Kavramı

Bir önceki bölümde öğrendiğimiz gibi, hash'leri kırmak için "tahminlerde" bulunmamız gerekir. Bu tahminlerin toplu halde bulunduğu metin dosyalarına **Wordlist** denir.

- **SecLists**: Sektör standardı olan, içinde milyonlarca kullanıcı adı, parola ve payload barındıran devasa bir depodur (repository).
- **Lokasyon**: Kali ve benzeri dağıtımlarda bu listeler genellikle şu dizinde bulunur: Bash

```
/usr/share/wordlists
```

Efsanevi Liste: RockYou.txt

Bu odadaki tüm görevlerde ve gerçek dünya sızma testlerinde en çok kullanılan liste **rockyou.txt**'dir.

- **Hikayesi**: 2009 yılında rockyou.com sitesinin veri ihlali (data breach) sonucunda sızan gerçek parolalardan oluşur.
- **Neden Önemli?** İnsanların şifre seçerken ne kadar tahmin edilebilir olduğunu (123456, password, qwerty vb.) kanıtlayan en iyi kaynaktır.

RockYou Hazırlığı

Eğer Kali kullanıyorsan, bu dosya genellikle sıkıştırılmış halde gelir. Kullanmadan önce açman gerekebilir:

Bash

```
# Dosyanın bulunduğu dizine git
cd /usr/share/wordlists

# .tar.gz formatındaysa şu komutla dışarı çıkar
sudo tar -xvzf rockyou.txt.tar.gz
```

Not: Eğer dosya sadece .gz uzantılıysa `gunzip rockyou.txt.gz` komutunu kullanmalısın. Dosyanın açık (plain text) halde olması, John'un okuma hızı için kritiktir.

Özet ve Hatırlatma

- Sürümün **Jumbo** olduğundan emin ol (yoksa yardımcı araçlar çalışmaz).
- **RockYou.txt** dosyasının yerini bil (`/usr/share/wordlists/rockyou.txt`).
- Eğer bu liste sisteminde yoksa, **SecLists** üzerinden indirebilirsin.

Temel Hash'leri Kırmak (Cracking Basic Hashes)

Bu bölümde, John the Ripper (JTR) kullanarak basit hash'leri nasıl kıracağımızı, hash türlerini nasıl tespit edeceğimizi ve John'a belirli bir formatı nasıl dayatacağımızı (forcing

format) öğreneceğiz.

1. John the Ripper Temel Sözdizimi (Syntax)

John'u çalıştırmak için en temel komut yapısı şöyledir:

Bash

```
john [seçenekler] [dosya_yolu]
```

- **john**: Programı çağırır.
- **[options]**: Kırma yöntemini, kullanılacak sözlüğü veya formatı belirlediğimiz parametrelerdir.
- **[file path]**: Kırılacak hash'in (veya hash'lerin) içinde bulunduğu dosya. Eğer aynı dizindeyseniz sadece dosya adını yazmanız yeterlidir.

2. Otomatik Kırma (Automatic Cracking)

John, kendisine verilen hash'in türünü otomatik olarak tahmin etme yeteneğine sahiptir. Ancak bu her zaman %100 güvenilir değildir. Eğer hash türünden emin değilseniz şu yöntemi kullanabilirsiniz:

Bash

```
john --wordlist=[wordlist_yolu] [hash_dosyası]
```

Örnek kullanım:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash_to_crack.txt
```

Mantık: Burada John'a "Sana bir wordlist veriyorum, hash dosyasındaki veriyi bu listedeki kelimelerle eşleştirmeyi dene, formatı sen tahmin et" diyoruz.

3. Hash Türünü Belirleme (Identifying Hashes)

John otomatik tanımda başarısız olursa veya biz daha kesin hareket etmek istersek, hash'in hangi algoritma (MD5, SHA1, NTLM vb.) ile oluşturulduğunu bulmamız gerekir.

hash-identifier Aracı

Bu iş için en popüler araçlardan biri Python tabanlı **hash-identifier**'dir. Eğer sisteminizde yoksa şu şekilde kurup çalıştırabilirsiniz:

Bash

```
# Aracı indir
wget https://gitlab.com/kalilinux/packages/hash-
identifier/-/raw/kali/master/hash-id.py

# Çalıştır
python3 hash-id.py
```

Aracı çalıştırdıktan sonra kırmak istediğiniz hash'i yapıştırın. Size "Possible Hashs" (Olası Hash'ler) başlığı altında en yüksek ihtimalli formatları verecektir. *Örneğin:*
*2e728dd31fb5949bc39cac5a9f066498 hash'ini girdiğinizde size bunun bir **MD5** olduğunu söyleyecektir.*

4. Belirli Bir Format ile Kırma (Format-Specific Cracking)

Hash türünü belirledikten sonra, John'un yanılma payını sıfıra indirmek ve işlemi hızlandırmak için formatı açıkça belirtmeliyiz.

Bash

```
john --format=[format] --wordlist=[path_to_wordlist] [hash_dosyası]
```

Örnek kullanım:

Bash

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt
hash_to_crack.txt
```

Formatlar Hakkında Kritik Not: `raw-` Öneki

John'da standart hash türlerini belirtirken genellikle ismin başına `raw-` eklemeniz gerekir (Örn: `raw-md5`, `raw-sha1`).

Hangi format isimlerini kullanabileceğinizi görmek için şu komutu kullanın:

Bash

```
john --list=formats
```

Eğer liste çok uzun gelirse (ki gelecektir), aradığınız formatı `grep` ile filtreleyebilirsiniz:

Bash

```
john --list=formats | grep -iF "md5"
```

Neden Önemli? Eğer formatı yanlış girerseniz John hash'i tanıyamaz ve "No password hashes loaded" hatası verir. Bu yüzden doğru format ismini bulmak başarının anahtarıdır.

Özet ve Akılda Kalması Gerekenler

- **Otomatik Tanıma:** Hızlı ama bazen hatalı (`--wordlist`).
- **Manuel Tanıma:** `hash-identifier` kullanarak kesinlik sağla.
- **Format Belirtme:** `--format=raw-md5` gibi spesifik komutlarla hata payını bitir.
- **Dizin Kontrolü:** Pratik yaparken dosyaların `~/John-the-Ripper-The-Basics/Task04/` dizini altında olduğunu unutma.

Windows Kimlik Doğrulama Hash'lerini Kırma (NTHash / NTLM)

Basit hash'lerden sonra, gerçek bir **Sızma Testi (Penetration Test)** veya **Red Team** operasyonunda karşımıza çıkma olasılığı en yüksek olan konuya geliyoruz: İşletim sistemi kimlik doğrulama hash'leri.

Bu notlarda, Windows'un parolaları nasıl sakladığını ve bu hash'leri ele geçirdiğimizde nasıl kıracağımızı inceleyeceğiz.

1. NTLM / NTHash Nedir?

Modern Windows işletim sistemleri (Windows 10, 11, Server 2019 vb.), kullanıcı ve servis parolalarını düz metin olarak değil, **NTHash** formatında saklar. Bu format siber güvenlik dünyasında genellikle **NTLM** (New Technology LAN Manager) olarak anılır.

Kısa Bir Tarihçe ve İsimlendirme:

- **NT (New Technology):** Microsoft'un MS-DOS tabanlı olmayan sistemleri için kullandığı bir isimdi. Bugün kullandığımız tüm modern Windows'lar bu mimari üzerindedir.
- **LM (LAN Manager):** Windows'un çok eski ve zayıf olan eski hash formatıdır.
- **NTLM:** Eski LM ve yeni NT formatlarının birleşimini ifade eden genel bir terim haline gelmiştir. Günümüzde sadece NT kısmı (NTHash) aktif olarak kullanılır.

2. Bu Hash'ler Nerede Bulunur?

Windows sistemlerde bu hash'leri elde etmek için genellikle sistemde **yüksek ayrıcalıklara (Administrator/System)** sahip olmanız gerekir. Hash'ler şu kaynaklardan "dump" edilebilir (dışarı aktarılabilir):

1. **SAM Veritabanı (Security Account Manager):** Yerel kullanıcıların bilgilerinin ve hash'lerinin tutulduğu dosyadır. **Mimikatz** gibi araçlarla bu veritabanı boşaltılabilir.
2. **NTDS.dit Dosyası:** Active Directory (Domain Controller) ortamında tüm domain kullanıcılarının hash'lerinin tutulduğu ana veritabanıdır.

Önemli Not: Bir sızma testinde hash'i kırmak her zaman şart değildir. **"Pass the Hash"** denilen teknikle, şifreyi hiç kırmadan doğrudan hash'i kullanarak da sistemde oturum açabilirsiniz. Ancak parola politikası zayıfsa, hash'i kırmak size düz metin şifreyi vereceği için daha değerlidir.

3. Pratik Uygulama: NTLM Kırma

Windows NTLM hash'lerini kırmak için John the Ripper'da `--format=nt` parametresini kullanırız. Bu format, NTLM hash yapısı için optimize edilmiştir.

Adım Adım Komut Yapısı:

1. Dosya Konumuna Git: Önce hedef dosyanın bulunduğu dizine geçiyoruz:

Bash

```
cd ~/John-the-Ripper-The-Basics/Task05/
```

2. Hash'i Kır: John'a formatın `nt` olduğunu ve hangi sözlüğü kullanacağını söylüyoruz:

Bash

```
john --format=nt --wordlist=/usr/share/wordlists/rockyou.txt ntlm.txt
```

Komut Parametrelerinin Analizi:

- `--format=nt` : John'a "Bu bir Windows NTLM hash'idir, buna göre işlem yap" talimatını verir. (Not: `raw-md5` gibi `raw-` ön eki burada gerekmez, doğrudan `nt` kullanılır).
- `--wordlist=...` : Dünyanın en popüler şifre listesi olan RockYou'yu hedef olarak gösterir.
- `ntlm.txt` : İçinde `Username:SID:LMhash:NtHash:::` formatında veya sadece hash şeklinde veri barındıran hedef dosyamız.

Kritik Hatırlatmalar

- Hız:** NTLM hash'leri, örneğin bir PDF şifresine göre çok daha hızlı kırılır (zayıf bir algoritmadır).
- Format Hatası:** Eğer `--format=nt` yazmayı unutursanız, John bu hash'i yanlışlıkla MD5 veya başka bir format sanabilir ve asla doğru sonucu bulamaz.
- Büyük/Küçük Harf:** NtHash (NTLM) **case-sensitive** (büyük/küçük harf duyarlı) bir yapıdadır. Bu yüzden wordlist'iniz ne kadar kaliteliyse başarı şansınız o kadar artar.

Linux /etc/shadow Hash'lerini Kırmak (Unshadowing İşlemi)

Linux sistemlerde kullanıcı parolaları Windows'tan farklı bir mantıkla saklanır. Bu bölümde, Linux'un parola saklama mekanizmasını ve John the Ripper'ın bu verileri okuyabilmesi için gereken **unshadow** işlemini öğreneceğiz

1. Linux Parola Saklama Mekanizması

Linux sistemlerde kullanıcı bilgileri iki ana dosyada tutulur:

- **/etc/passwd**: Sistemdeki tüm kullanıcıları listeler. Eskiden parolalar burada tutulurdu ancak güvenlik nedeniyle artık parola kısmında sadece bir "x" işareti bulunur. Bu dosya herkes tarafından okunabilir.
- **/etc/shadow**: Asıl parola hash'lerinin bulunduğu dosyadır. Sadece **root** yetkisiyle okunabilir. İçinde parolanın son değiştirilme tarihi ve son kullanma tarihi gibi kritik bilgiler de yer alır.

2. Unshadowing: Dosyaları Birleştirme

John the Ripper, sadece `/etc/shadow` dosyasını alıp kırmaya çalışmaktan pek hoşlanmaz. John'un hangi hash'in hangi kullanıcıya ait olduğunu ve kullanıcı yetkilerini tam olarak anlayabilmesi için bu iki dosyanın birleştirilmesi gerekir. Bu işleme **Unshadowing** denir.

John ile birlikte gelen **unshadow** aracı bu birleştirme işlemini otomatik yapar.

unshadow Kullanımı:

Bash

```
unshadow [passwd_dosyası] [shadow_dosyası] > [çıkış_dosyası]
```

Örnek Senaryo: Hedef makineden `/etc/passwd` ve `/etc/shadow` dosyalarını ele geçirdiğimizi (veya içindeki ilgili satırları kopyaladığımızı) varsayalım:

Bash

```
unshadow local_passwd local_shadow > unshadowed.txt
```

Mantık: Bu komut, iki dosyadaki verileri eşleştirir ve John'un istahla okuyabileceği `unshadowed.txt` adında yeni bir dosya oluşturur.

3. Hash Kırma (Cracking) Aşaması

Elimizde `unshadowed.txt` dosyası olduktan sonra klasik John komutumuza geçebiliriz. John genellikle bu formatı otomatik tanır, ancak modern Linux sistemlerinde (Ubuntu 18.04+ gibi) kullanılan **SHA-512** hash'leri için format belirtmek işi garantiye alır.

Komut Yapısı:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=sha512crypt  
unshadowed.txt
```

Parametre Detayları:

- `--format=sha512crypt` : Linux'un modern dağıtımlarında kullandığı standart hash formatıdır. Eğer hash `$6$` ile başlıyorsa bu bir SHA-512 hash'idir.
- `unshadowed.txt` : `unshadow` aracından çıkan, birleştirilmiş dosyamız.

4. Pratik Uygulama (Task 06)

Şimdi öğrendiklerimizi uygulama zamanı. Dosyalarımız `~/John-the-Ripper-The-Basics/Task06/` dizininde bulunuyor.

Adım Adım İzlenecek Yol:

1. **Dizine git:** `cd ~/John-the-Ripper-The-Basics/Task06/`
2. **Dosyaları birleştir:** Eğer içeride ayrı ayrı `passwd` ve `shadow` dosyaları varsa `unshadow` komutuyla birleştir. (Not: Eğer THM size doğrudan birleşik bir dosya veriyse bu adımı geçebilirsiniz.)
3. **Kırma işlemini başlat:** ```bash john --wordlist=/usr/share/wordlists/rockyou.txt etchashes.txt`

Not: Eğer John hata verirse `--format=sha512crypt` ekleyerek tekrar dene.

Unutulmaması Gerekenler (Pro İpuçları)

- **Yetki:** Gerçek bir sistemde `/etc/shadow` dosyasını okuyabilmek için `sudo` yetkisine veya bir şekilde sistemde yüksek haklara (Privilege Escalation) sahip olman gerekir.
- **\$ İşaretleri:** Hash'in başındaki karakterler algoritmayı ele verir:
 - `$1$` : MD5
 - `$2a$` : Blowfish
 - `$5$` : SHA-256
 - `$6$` : SHA-512 (En yaygın olanı)

John the Ripper: Single Crack Mode

Bu mod, John the Ripper'ın (JtR) en zeki ve verimli çalışma modlarından biridir. Genelde bir sızma testinde elimizde büyük bir wordlist yoksa veya hedef kullanıcıların "zayıf/tahmin edilebilir" şifreler koyduğunu düşünüyorsak ilk başvuracağımız yöntemdir. Mantık basittir:

İnsanlar şifre oluştururken tembellik eder ve genellikle kullanıcı adlarını veya kişisel bilgilerini temel alıp sonuna bir iki rakam ya da sembol eklerler.

Single Crack Mode Nedir?

Şimdiye kadar John'u hep **Wordlist Mode** (hazır bir kelime listesi kullanarak deneme yapma) ile kullandık. Ancak **Single Crack** modu, dışarıdan devasa bir liste beslemek yerine, elindeki kısıtlı bilgiden (kullanıcı adı, GECOS bilgisi vb.) yola çıkarak kendi kelime listesini dinamik olarak oluşturur.

John bu modda **Heuristic** (sezgisel) bir yaklaşım sergiler. Yani kullanıcı adını alır, onu evirir çevirir, harflerini değiştirir ve ortaya binlerce varyasyon çıkarır.

Word Mangling (Kelime Harmanlama/Evirme)

John'un bir kelimeyi alıp ondan yeni olasılıklar türetmesine **Word Mangling** denir. Hedefin kullanıcı adının **Markus** olduğunu varsayalım. John, "mangling rules" (harmanlama kuralları) adını verdiği kurallar setini uygulayarak şu tarz şifreleri otomatik olarak üretip dener:

- **Sayı ekleme:** Markus1, Markus123, 2024Markus
- **Büyük/Küçük harf varyasyonları:** MArkus, MARKUS, mArKuS
- **Sembol ekleme:** Markus!, Markus?, @Markus
- **Kombinasyonlar:** M4rkus2023!

Bu yöntem, insanların kullanıcı adı veya hizmet adıyla bağlantılı şifre seçme zayıflığını (zayıf parola politikaları) doğrudan istismar eder.

GECOS Bilgisinin Rolü

Linux ve UNIX benzeri sistemlerde `/etc/passwd` dosyasını incelediğimizde, her satırın iki nokta üst üste (:) ile ayrılmış yedi alandan oluştuğunu görürüz. Bu dosyadaki **beşinci alan GECOS** (General Electric Comprehensive Operating System) alanıdır.

GECOS alanı şu bilgileri barındırabilir:

- Kullanıcının tam adı ve soyadı
- Oda numarası
- İş telefonu
- Ev telefonu

John, **Single Crack** modunda çalışırken sadece kullanıcı adını değil, eğer dosyada varsa bu GECOS alanındaki tam isim, telefon numarası gibi bilgileri de "mangling" işlemine dahil eder. Örneğin kullanıcı adı `jdoe` olan birinin tam adı GECOS alanında `John Doe` olarak geçiyorsa, `John`; `John` , `Doe` , `JDoe123` gibi varyasyonları da listesine ekler. Bu, başarı oranını devasa ölçüde artırır.

Single Crack Modu Kullanımı ve Sözdizimi (Syntax)

Bu modu kullanırken temel komut yapımız şu şekildedir:

Bash

```
john --single --format=[format_tipi] [dosya_yolu]
```

- `--single` : John'a "Single Crack" modunda çalışacağını bildirir.
- `--format=[format]` : Kırılacak hash'in tipini (md5, raw-sha256, nt vb.) belirtir. Doğru formatı seçmek, John'un hash'i tanınması için kritiktir.

Örnek Senaryo: Eğer elimizde `Mike` kullanıcısına ait bir SHA-256 hash'i varsa:

Bash

```
john --single --format=raw-sha256 hashes.txt
```

Kritik Nokta: Dosya Formatını Hazırlama

Single Crack modunun en önemli kuralı şudur: John, hangi kelimeyi evirip çevireceğini bilmek zorundadır. Eğer hash dosyasında sadece hash varsa, John bunun kime ait olduğunu bilemez ve "mangling" yapamaz.

Bu yüzden dosyayı John'a vermeden önce şu formatta düzenlemeliyiz:

```
kullanıcı_adi:hash
```

- **Hatalı Format:** `1efee03cdcb96d90ad48ccc7b8666033`
- **Doğru Format:** `mike:1efee03cdcb96d90ad48ccc7b8666033`

Bu şekilde John, `mike` kelimesini baz alarak varyasyonlar türetmesi gerektiğini anlar.

Uygulama: "Joker" Kullanıcısının Parolasını Kırma

Senaryomuzda hedef kullanıcı adının **Joker** olduğunu biliyoruz. Elimizde bir hash dosyası var ve bu dosya `~/John-the-Ripper-The-Basics/Task07/` dizininde bulunuyor.

1. Adım: Dosyayı Hazırlama

Öncelikle hash'in başına kullanıcı adını ekleyerek John'un anlayacağı formata getiriyoruz. Dosyayı `nano` veya `echo` ile şu hale getirmiş olmalısın: `joker:<hash_değeri>`

2. Adım: Komutu Çalıştırma

Dosya hazırlandıktan sonra ilgili dizine gidip şu komutu yürütüyoruz:

Bash

```
john --single --format=raw-sha256 hashes.txt
```

Neden bu komut?

- `--single` kullandık çünkü elimizde bir wordlist yok, kullanıcı adından yola çıkmak istiyoruz.
- `--format=raw-sha256` belirledik (hash tipinin bu olduğunu varsayıyoruz).
- `hashes.txt` içinde `joker`: ön eki olduğu için John artık `Joker1` , `Joker!` , `j0ker` gibi denemeler yaparak şifreyi saniyeler içinde çözecektir.

Unutma: Single Crack modu, özellikle sızma testlerinin başında "low-hanging fruit" dediğimiz kolay hedefleri yakalamak için altın değerindedir. Eğer kullanıcı adı üzerinden bir sonuç alınamazsa, o zaman daha kapsamlı wordlist modlarına geçilir.

John the Ripper: Custom Rules (Özel Kurallar)

Bir sızma testinde veya CTF çözümünde, Single Crack modu işe yaramadığında ve standart wordlist'ler yetersiz kaldığında **Custom Rules** (Özel Kurallar) devreye girer. Bu mod, John'un elindeki bir kelime listesini (wordlist) alıp, sizin belirlediğiniz matematiksel ve mantıksal kurallara göre "modifiye" etmesini sağlar.

Neden Özel Kurallara İhtiyaç Duyarız?

Günümüzde kurumlar genellikle belirli bir "parola karmaşıklığı" (password complexity) politikası uygular. Bir şifrenin geçerli olması için genelde şu kriterler istenir:

- En az bir **büyük harf**
- En az bir **küçük harf**
- En az bir **rakam**
- En az bir **özel karakter (sembol)**

İnsan doğası gereği tahmin edilebilirdir. `po!opassword` gibi basit bir şifre yasaklandığında, kullanıcılar genelde en kolay yolu seçer ve bunu `Po!opassword1!` haline getirir.

İşte saldırganın (bizim) fırsatı: Şifrenin başına büyük harf geleceğini, sonuna ise bir rakam ve bir sembol ekleneceğini tahmin edebiliriz. Özel kurallar sayesinde John'a "Listemdeki her kelimenin ilk harfini büyüt, sonuna 0-9 arası bir rakam ekle ve yanına bir sembol koy" diyebiliriz.

Kurallar Nerede Tanımlanır?

John'un kuralları `john.conf` adlı yapılandırma dosyasında saklanır. Bu dosyanın konumu sisteminize göre değişebilir:

- **TryHackMe AttackBox:** `/opt/john/john.conf`
- **Paket yöneticisi (apt vb.) ile kurulum:** `/etc/john/john.conf`

Yeni bir kural eklemek için bu dosyayı bir metin düzenleyici (`nano` veya `vim`) ile açıp en alta veya uygun bir bölüme kendi kurallarımızı eklememiz gerekir.

Kural Yazımı ve Sözdizimi (Syntax)

Bir kural oluştururken temel yapı şöyledir:

1. Kural İsmi Tanımlama

Plaintext

```
[List.Rules:KuralAdim]
```

Bu satır, kuralın başlangıcını ve adını belirtir. John'u çalıştırırken bu ismi `--rule=KuralAdim` şeklinde çağıracağız.

2. Modifikatörler (Değiştiriciler)

Kuralın altına yazdığımız karakterler, kelimenin nasıl değişeceğini belirler:

- `c` : (Capitalize) Kelimenin ilk harfini büyütür, diğerlerini küçültür.
- `Az` : (Append) Kelimenin **sonuna** karakter ekler.
- `A0` : (Prepend) Kelimenin **başına** karakter ekler.

3. Karakter Setleri

Hangi karakterlerin ekleneceğini köşeli parantez `[]` içinde belirtiriz:

- `[0-9]` : 0'dan 9'a kadar tüm rakamlar.
- `[A-Z]` : Tüm büyük harfler.
- `[!£$%@]` : Sadece bu özel semboller.

Pratik Örnek: PoLopassword1! Kuralı

Diyelim ki elimizdeki listede `polopassword` kelimesi var ve biz bunu `PoLopassword1!` formatına dönüştürmek istiyoruz.

Yazmamız gereken kural:

Plaintext

```
[List.Rules:PoLoPassword]  
cAz"[0-9][!£$%@]"
```

Analiz edelim:

- `c` : `polopassword` -> `PoLopassword` (İlk harf büyüdü).
- `Az` : "Sonuna ekleme yapacağım" komutu.
- `"[0-9][!£$%@]"` : Kelimenin sonuna önce 0-9 arası bir rakam, sonra da tırnak içindeki sembollerden birini ekle.

Bu tek satırlık kural sayesinde John, listedeki her bir kelime için onlarca varyasyon üretir (Örn: Polopassword1! , Polopassword2\$, vb.).

Özel Kuralları Çalıştırmak

Kuralımızı `john.conf` dosyasına kaydedip çıktıktan sonra, terminalde şu komutu kullanarak saldırıyı başlatırız:

Bash

```
john --wordlist=[wordlist_yolu] --rule=Polopassword [hash_dosyası_yolu]
```

- `--wordlist` : Baz alınacak ham kelime listesi.
- `--rule=Polopassword` : `john.conf` içine yazdığımız özel kuralın ismi.
- `[hash_dosyası]` : Kırmak istediğimiz hash'lerin bulunduğu dosya.

John the Ripper: Parola Korumalı Zip Dosyalarını Kırmak

John the Ripper'in yetenekleri sadece sistem hash'leri (Linux shadow dosyaları vb.) ile sınırlı değildir. Günlük hayatta sıkça karşımıza çıkan **parola korumalı Zip arşivlerini** kırmak için de mükemmel bir araçtır.

Süreç, daha önce gördüğümüz `unshadow` mantığına çok benzer: Önce Zip dosyasını John'un anlayabileceği bir "hash" formatına dönüştürüyoruz, sonra bu hash'i kırıyoruz.

Zip2John Aracı

Zip dosyalarının içindeki şifreyi doğrudan kırmaya çalışmak yerine, John suite içerisinde yer alan **zip2john** adlı yardımcı aracı kullanırız. Bu araç, Zip dosyasının başlık (header) ve şifreleme bilgilerini ayıklayarak bize bir metin dosyası (hash) verir.

Temel Sözdizimi (Syntax)

Bash

```
zip2john [seçenekler] [zip_dosyası] > [çıktı_dosyası]
```

- **[seçenekler]**: Checksum ayarları gibi teknik parametreler eklenebilir ancak standart kullanımda buna pek ihtiyaç duyulmaz.
- **[zip_dosyası]**: Parolasını kırmak istediğimiz hedef Zip dosyasının yolu.
- **> (Yönlendirme)**: Komutun çıktısını ekrana yazdırmak yerine bir dosyaya kaydetmemizi sağlar.
- **[çıktı_dosyası]**: Hash bilgisinin kaydedileceği dosya adı (Örn: `zip_hash.txt`).

Örnek Kullanım:

Bash

```
zip2john gizli_dosyalar.zip > zip_hash.txt
```

Bu komutu çalıştırdığımızda, `zip_hash.txt` dosyasının içinde Zip dosyasına dair hash verisi oluşacaktır.

Kırma İşlemi (Cracking)

Hash dosyasını oluşturduktan sonra, geri kalan adımlar bildiğimiz John kullanımıyla aynıdır. Artık elimizde John'un tanıyabileceği bir dosya olduğu için istediğimiz wordlist veya kuralı (rule) uygulayabiliriz.

Komut Yapısı:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt zip_hash.txt
```

John bu noktada şunu yapar:

1. `rockyou.txt` içindeki her bir kelimeyi alır.
2. `zip_hash.txt` içindeki algoritma türüne göre hash'ler.
3. Elde ettiği sonucu, dosyadaki orijinal hash ile karşılaştırır.
4. Eşleşme bulduğunda parolayı ekrana basar.

Uygulama: "Güvenli" Zip Dosyasını Kırma

Hadi şimdi `~/John-the-Ripper-The-Basics/Task09/` dizinindeki dosyayı ele alalım.

1. Adım: Hash Çıkartma

Önce hedef dizine gidiyoruz ve Zip dosyasını hash formatına çeviriyoruz:

Bash

```
cd ~/John-the-Ripper-The-Basics/Task09/  
zip2john secure.zip > secure_hash.txt
```

2. Adım: Saldırıyı Başlatma

Şimdi `rockyou.txt` (Linux sistemlerde standart wordlist yoludur) kullanarak hash'i kırmaya çalışıyoruz:

Bash


```
john --wordlist=/usr/share/wordlists/rockyou.txt secure_hash.txt
```

3. Adım: Sonucu Görüntüleme

John şifreyi bulduğunda ekrana yazacaktır. Eğer ekranı kaçıırırsanız veya daha sonra tekrar bakmak isterseniz şu komutu kullanabilirsiniz:

Bash

```
john --show secure_hash.txt
```

John the Ripper: Parola Korumalı RAR Arşivlerini Kırmak

Zip dosyalarında olduğu gibi, parola korumalı **RAR** arşivlerini kırmak için de John the Ripper ailesinin bir parçası olan özel bir dönüştürücü kullanıyoruz. RAR dosyaları, WinRAR tarafından oluşturulan sıkıştırılmış dosya formatlarıdır ve içerdikleri verileri korumak için güçlü şifreleme yöntemleri kullanabilirler. Ancak çalışma mantığımız bir önceki görevle neredeyse tamamen aynıdır.

Rar2John Aracı

RAR dosyalarıyla doğrudan çalışmak yerine, öncelikle dosyanın içindeki hash bilgisini ayıklamamız gerekir. Bu iş için **rar2john** aracını kullanıyoruz. Bu araç, RAR arşivinin şifrelenmiş başlıklarından gerekli veriyi çekip John'un saldırı gerçekleştirebileceği bir metin formatına dönüştürür.

Temel Sözdizimi (Syntax)

Bash

```
rar2john [rar_dosyası] > [çıktı_dosyası]
```

- **rar2john**: Hash çıkartma aracını çağırır.
- **[rar_dosyası]**: Hedeflediğimiz parola korumalı RAR dosyasının yolu.
- **> (Yönlendirme)**: Komutun çıktısını ekrana basmak yerine belirtilen dosyaya yazar.
- **[çıktı_dosyası]**: John ile saldırı yaparken kullanacağımız hash dosyasının adı.

Örnek Kullanım:

Bash

```
/opt/john/rar2john rar_belgelerim.rar > rar_hash.txt
```

Not: Sisteminizde rar2john doğrudan tanımlı değilse, yukarıdaki gibi tam yolu (/opt/john/rar2john) kullanmanız gerekebilir.

Kırma İşlemi (Cracking)

rar2john ile oluşturduğumuz rar_hash.txt dosyası, artık John'un üzerinde işlem yapabileceği ham veriyi barındırır. Bu aşamadan sonra standart wordlist saldırısı prosedürünü uyguluyoruz.

Komut Yapısı:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt rar_hash.txt
```

Neden bu adımı yapıyoruz? RAR şifreleme algoritmaları (özellikle RAR5) Zip'e göre matematiksel olarak daha maliyetli olabilir. John, wordlist'teki her kelimeyi bu ağır algoritmaya göre hesaplayıp elimizdeki hash ile karşılaştırarak doğru parolayı bulmaya çalışır.

Uygulama: "Güvenli" RAR Dosyasını Kırma

Hadi ~/John-the-Ripper-The-Basics/Task10/ dizinindeki "secure" RAR dosyasını ele geçirelim.

1. Adım: Hash Bilgisini Ayıklama

Hedef dizine gidiyoruz ve RAR dosyasını John'un anlayacağı dile çeviriyoruz:

Bash

```
cd ~/John-the-Ripper-The-Basics/Task10/  
rar2john secure.rar > rar_hash.txt
```

2. Adım: Saldırı Modunu Başlatma

Dünyanın en popüler kelime listesi olan rockyou.txt ile hash'i kırmaya başlıyoruz:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt rar_hash.txt
```

3. Adım: Sonuçları Kontrol Etme

Saldırı bittiğinde (veya parola bulunduğunda) ekranda sonucu göreceksin. Eğer ekranı temizlediysen veya parolayı tekrar görmek istersen:

Bash

```
john --show rar_hash.txt
```

John the Ripper: SSH Anahtarlarını (id_rsa) Kırmak

Arşiv dosyalarını (Zip, RAR) geride bıraktık ama John'un yetenekleri bitmedi. CTF (Capture The Flag) yarışmalarında ve sızma testlerinde en sık karşılaşılan senaryolardan biri şudur: Hedef sistemden bir **id_rsa** (SSH Özel Anahtarı) dosyası ele geçirirsiniz, ancak anahtarı kullanmaya çalıştığınızda size bir **passphrase** (parola) sorar.

Eğer bu parolayı bilmiyorsanız anahtar hiçbir işe yaramaz. İşte burada John the Ripper devreye girer ve o özel anahtarı koruyan parolayı kırmamızı sağlar.

SSH Key-Based Authentication Nedir?

Normalde SSH ile bir makineye bağlanırken kullanıcı parolası gireriz. Ancak daha güvenli bir yöntem olan "anahtar tabanlı kimlik doğrulama" (key-based authentication) kullanıldığında, elimizdeki **id_rsa** dosyası bir dijital anahtar görevi görür.

Güvenliği artırmak için bu anahtar dosyasının kendisi de bir parola ile şifrelenebilir. Bu durumda saldırgan anahtarı çalsa bile, parolayı kırmadan anahtarı kullanamaz. Bizim amacımız bu parolayı (passphrase) düşürmektir.

SSH2John Aracı

Her zaman olduğu gibi, John bu anahtar dosyasını doğrudan okuyamaz. Anahtarın içindeki şifreli kısmı John'un anlayacağı bir hash formatına çevirmemiz gerekir. Bunun için **ssh2john** aracını kullanıyoruz.

Önemli Not: ssh2john Nerede?

Eğer sisteminizde **ssh2john** komutu doğrudan çalışmıyorsa, bu araç aslında bir Python betiğidir. Konumu sisteminize göre değişebilir:

- **TryHackMe AttackBox:** `python3 /opt/john/ssh2john.py`
- **Kali Linux:** `python /usr/share/john/ssh2john.py`

Temel Sözdizimi (Syntax)

Bash

```
python3 /opt/john/ssh2john.py [id_rsa_dosyası] > [çıktı_dosyası]
```

- **[id_rsa_dosyası]:** Ele geçirdiğimiz SSH özel anahtarının yolu.
- **> (Yönlendirme):** Üretilen hash'i bir dosyaya kaydeder.

- **[çıktı_dosyası]:** John'a vereceğimiz hash dosyasının adı (Örn: `id_rsa_hash.txt`).

Örnek Kullanım:

Bash

```
python3 /opt/john/ssh2john.py id_rsa > id_rsa_hash.txt
```

Kırma İşlemi (Cracking)

Hash dosyasını oluşturduktan sonra süreç artık standart bir John saldırısına dönüşür. Yine en güvenilir dostumuz olan `rockyou.txt` listesini kullanabiliriz.

Komut:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa_hash.txt
```

John, SSH anahtarını şifreleyen algoritmayı otomatik olarak tanıyacak ve listedeki kelimeleri deneyerek anahtarı "açacak" olan parolayı bulmaya çalışacaktır.

Uygulama: SSH Anahtar Parolasını Ele Geçirme

Şimdi `~/John-the-Ripper-The-Basics/Task11/` dizinindeki anahtarı kiralım.

1. Adım: Hash Çıkarma

Önce ilgili dizine gidiyoruz ve anahtarı hash formatına dönüştürüyoruz:

Bash

```
cd ~/John-the-Ripper-The-Basics/Task11/  
python3 /opt/john/ssh2john.py id_rsa > id_rsa_hash.txt
```

2. Adım: John ile Saldırı

Şimdi hash dosyasını kırmak için John'u çalıştırıyoruz:

Bash

```
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa_hash.txt
```

3. Adım: Anahtarı Kullanma (Bonus Bilgi)

Parolayı bulduktan sonra SSH anahtarını kullanmak için şu komutu kullanabilirsin:

Bash

```
ssh -i id_rsa kullanıcı_adi@hedef_ip
```

(Sana parola sorduğunda John'un bulduğu o parolayı gireceksin!)